

NexaHR

بازبینی ماژول‌های دسترسی، نوتیفیکیشن و مسیر پرونده ارزیابی

بازبینی عمیق مخزن github.com/sanyzm/NexaHR با تمرکز بر راه‌اندازی سازمان و تخصیص اولیه دسترسی‌ها، گردش کار پرونده، و سامانه اعلان‌ها؛ به همراه یافته‌های اولویت‌بندی‌شده، دیاگرام فرآیند اصلاحی و نقشه راه سه‌فازی.

اوربوردینگ سازمان

مسیر پرونده

نوتیفیکیشن‌ها

دسترسی‌ها و نقش‌ها

مخزن: github.com/sanyzm/NexaHR · کامیت مبنا: 27c83e5

دامنه: بک‌اند FastAPI (+۶۰ ماژول)، فرانت‌اند React/TS، مایگريشن‌ها و تست‌ها

تاریخ تهیه: شهریور ۱۴۰۵

فهرست مطالب

1. خلاصه مدیریتی
2. سناریوی کلیدی: راه‌اندازی سازمان ۳ نفره و تخصیص اولیه دسترسی‌ها
3. مازول دسترسی‌ها و نقش‌ها
4. مازول نوتیفیکیشن‌ها
5. مازول مسیر پرونده (زنجیره ارزیابی)
6. پایداری، عملیات و تجربه کاربری
7. جدول خلاصه یافته‌ها و اولویت‌بندی
8. نقشه راه پیشنهادی سه‌فازی
9. پیوست فنی: مراجع خطبه‌خط کد

بخش ۱

خلاصه مدیریتی

در این بازبینی، مخزن NexaHR در نسخه ۱/۱۷/۰ (کامیت 27c83e5) به صورت خطبه‌خط در چهار محور درخواستی بررسی شد: راه‌اندازی سازمان و تخصیص اولیه دسترسی‌ها، سامانه نوتیفیکیشن، مسیر پرونده ارزیابی و مدل دسترسی و نقش‌ها. جمع‌بندی کلی ما مثبت است: پایه مهندسی این پروژه قوی‌تر از میانگین پروژه‌های مشابه است – ماشین حالت اعلانی برای زنجیره ارزیابی، لاگ ممیزی با زنجیره هش، جدایی «نقش» از «مجوز اداری»، صف تحویل با retry و backoff نمایی، و ۳۳۰+ تست، نشان‌دهنده بلوغ واقعی هستند. با این حال، در مرز «راه‌اندازی اولیه» و «قابل دیدن بودن خرابی‌ها»، شکاف‌های جدی وجود دارد که در استقرار واقعی اولین سازمان، به سرعت هزینه‌ساز می‌شود.

۱۱

کم

۱۲

متوسط

۳

بالا

۲۶

یافته تأییدشده

۴

دیاگرام و جدول اصلاحی

سه پیام اصلی این گزارش

- سناریوی «۱ مسئول ۲ HR + کارمند» امروز با پنل ادمین قابل استقرار است، اما نه به شکلی که تصور می‌شود: اولین حساب (ادمین bootstrap) بیرون از پنل و خودکار ساخته می‌شود، حساب HR از پنل ساخته می‌شود، اما زنجیره ارزیابی بدون یک حساب مدیرعامل اصلاً شکل نمی‌گیرد – چیزی که در سناریوی سه‌نفره شما غایب است و نه UI و نه راهنما آن را اعلام می‌کند. جزئیات کامل و دیاگرام اصلاحی در بخش ۲.
- اعلان‌ها «می‌روند» اما خرابی‌شان نامرئی است: زیرساخت اعلان درون برنامه‌ای و کانال‌های ایمیل/پیامک با کیفیت ساخته شده، ولی هیچ صفحه‌ای برای دیدن «صف تحویل» وجود ندارد (API هست، UI نیست) و مجوز دیدنش هم در پیش‌فرض HR نیست. اگر SMTP خراب شود، هیچ‌کس در محصول نمی‌فهمد.

- چند شکاف اطلاع‌رسانی واقعی در گردش کار باقی است: کامنت‌های مرحله پرونده هیچ‌کس را مطلع نمی‌کند، کارمند هدف «برنامه بهبود» هرگز خبردار نمی‌شود، و کارمند از لغو پرونده خودش بی‌خبر می‌ماند. این سه مورد جزو اصلاحات پرتکرار روزمره‌اند و پیشنهاد می‌شود در اولین اسپرینت بسته شوند.

خلاصه یافته‌های کلیدی

یافته	ماژول	شدت	پیامد عملی
نامرئی بودن شکست اعلان‌های بیرونی (نبودن آلا صف تحویل + مجوز پیش‌فرض ناکافی HR)	نوتیفیکیشن	بالا	SMTP/پیامک خراب را هیچ‌کس در محصول نمی‌بیند؛ «چرا فلانی خبردار نشد؟» بی‌جواب می‌ماند
ادمین اولیه بیرون‌ازپنل + رمز یک‌بارمصرف در لاگ + ساخت‌نشدن حساب «پشتیبانی» از آلا	دسترسی‌ها	بالا	گم‌شدن رمز bootstrap = وابستگی به SSH؛ دستورالعمل تفکیک وظایف داخل محصول قابل اجرا نیست
زنجیره ارزیابی بدون حساب مدیرعامل ممکن نیست؛ HR هم نمی‌تواند در صندلی‌های زنجیره بنشیند	مسیر پرونده	بالا	سناریوی ۳ نفره بدون مدیرعامل در بن‌بست پیام‌های نامفهوم گیر می‌کند
اعتبارسنجی فرمت ایمیل/شماره موبایل وجود ندارد (هر رشته‌ای ذخیره می‌شود)	نوتیفیکیشن	متوسط	شکست تحویل تضمین‌شده و هزینه SMS بیهوده؛ خطا فقط در لاگ سرور دیده می‌شود
کامنت‌های سطح بالای پرونده اطلاع‌رسانی ندارند (فقط پاسخ تودرتو اعلان دارد)	نوتیفیکیشن	متوسط	نتیجه برگشت‌ها/توضیحات فقط با ورود دستی به پرونده فهمیده می‌شود
کارمند هدف «برنامه بهبود» از ساخت/تکمیل/لغو آن هرگز مطلع نمی‌شود	نوتیفیکیشن	متوسط	فردی که برنامه برایش نوشته شده، حداکثر به‌طور تصادفی می‌فهمد
کارمند از لغو پرونده خودش اعلان نمی‌گیرد (گیرندگان فقط صندلی‌های زنجیره‌اند)	مسیر پرونده	متوسط	کارمند منتظر نتیجه‌ای می‌ماند که برای همیشه لغو شده
پاک‌سازی بی‌صدا و تخریبی مجوزها هنگام «تعریف دوباره نقش HR»	دسترسی‌ها	متوسط	مجوزهای دستی اضافه‌شده با یک تغییر نقش بی‌رسنا حذف می‌شوند
ادمین نمی‌تواند ایمیل/موبایل کاربران را ثبت کند (فقط خود کاربر از تنظیمات خودش)	دسترسی‌ها	متوسط	پس از اوربوردینگ، کانال‌های بیرونی عملاً تا خود-پیکربندی تک‌تک کاربران خاموش‌اند
نبودن آلا «بازکردن حساب قفل‌شده» با وجود وجود endpoint	دسترسی‌ها	متوسط	قفل ۵ اشتباه = ۱۵ دقیقه تعطیلی حساب؛ HR نه وضعیت قفل را می‌بیند نه دکمه‌ای برای رفعش دارد

یافته	ماژول	شدت	پیامد عملی
دکمه «اجرا یادآوری‌ها» داشبورد HR برای HR پیش‌فرض همیشه ۴۰۳ می‌دهد	رابط کاربری	متوسط	دکمه‌ای نمایش داده می‌شود که کار خوش‌بینانه‌اش شکست است
بدون سیاست پاک‌سازی، جداول اعلان و تحویل بی‌سقف رشد می‌کنند	پایداری	متوسط	افت تدریجی کارایی زنگوله و ایندکس‌ها در بلندمدت

یادداشت روش: اسکوپ امنیتی (آسیب‌پذیری‌های عمومی مثل IDOR، JWT، تزریق) طبق توافق خارج شد و به منطق کسب‌وکار دسترسی‌ها محدود ماند. مواردی که فقط از جنس «عملیات و دسترسی» با بازبینی امنیتی هم‌پوشانی دارند (مثل rate-limit چندورکری) در بخش ۶ آمده‌اند. مستند داخلی docs/open-findings.md پروژه هم خوانده و با کد فعلی مقایسه شد – دو مورد از یافته‌های آن در کد فعلی قبلاً برطرف شده و سند عقب است (بخش ۵).

بخش ۲

سناریوی کلیدی: راه‌اندازی سازمان ۳ نفره و تخصیص اولیه دسترسی‌ها

پرسش کلیدی شما این بود: «اگر سازمانی با یک مسئول واحد منابع انسانی و دو کارمند در پلتفرم ثبت شود، در ابتدا چطور به هر سه نفر دسترسی داده می‌شود؟» پاسخ دقیق این است که در **معماری فعلی، مفهوم «ثبت سازمان» اصلاً وجود ندارد** – هر استقرار (Deployment) یک سازمان است و جدول Organization یا Tenant در کل مدل داده وجود ندارد. پس «ثبت سازمان» یعنی استقرار یک نمونه جدید، و «تخصیص دسترسی اولیه» یعنی زنجیره‌ای از قدم‌های دستی که در ادامه گام‌به‌گام بازش می‌کنیم.

۲/۱ – پاسخ مستقیم: امروز دقیقاً چه اتفاقی می‌افتد؟

گام صفر (خارج از پنل): به محض بالاآمدن سرویس روی نصب تازه، تابع `ensure_bootstrap_admin` چک می‌کند آیا کسی مجوز `manage_capabilities` دارد؛ اگر نه، حسابی با نام `admin` و نقش `support` (پشتیبانی فنی) با **تمام** ۹ مجوز اداری می‌سازد. رمز یا از متغیر محیطی `NEXAHR_ADMIN_PASSWORD` می‌آید یا تصادفی تولید و **فقط یک بار** در **لاگ سرویس** چاپ می‌شود. این حساب تنها راه ورود به پنل است.

گام ۱ (از پنل – ساخت حساب HR): ادمین با این حساب وارد می‌شود و از صفحه «حساب‌های کاربری» یک کاربر با نقش **منابع انسانی** می‌سازد. سرور به‌طور خودکار سه مجوز پیش‌فرض HR (`manage_users`، `manage_personnel`، `manage_scoring`) را به او می‌دهد. یعنی پاسخ بخش اول پرسش شما: **دسترسی HR از پنل ادمین داده می‌شود و خودکار است – ولی فقط برای یک نفر، و فقط همان سه مجوز.**

گام ۲ (از پنل – ثبت پرسنل): پرسنل (دو کارمند + خود مسئول HR اگر بخواهد خودارزیابی داشته باشد) از صفحه «پرسنل» یا با ایمپورت اکسل ثبت می‌شوند. ثبت پرسنل **مدیرعامل** زنجیره‌ای اجباری می‌خواهد – یعنی سازمان شما باید حساب مدیرعامل داشته باشد، حتی اگر در سازمان واقعی چنین سمتی ندارید.

گام ۳ (از پنل – حساب کارمندان): برای هر پرسنل، حساب کاربری با نقش **کارمند** و پیوند به پرونده پرسنلی ساخته می‌شود (یا همزمان با ثبت پرسنل، یا بعدش). حساب کارمند هیچ مجوز اداری نمی‌گیرد و به صف HR هم دسترسی

ندارد – این تفکیک عمدی است و در سرور هم قفل شده (به کارمند اجازه مجوز اداری داده نمی‌شود).

گام ۴ (توسط HR): مسئول HR که حالا وارد شده، تنظیم زنجیره ارزیابی هر پرسنل (مسئول مستقیم اختیاری، معاونت اختیاری، مدیرعامل اجباری) و «ساخت دسته‌ای ارزیابی» در دوره ارزیابی را انجام می‌دهد. هر دو کارمند اعلان درون برنامه‌ای «N ارزیابی برای شما آغاز شد» می‌گیرند.

پس «دسترسی منابع انسانی برای هر سه نفر» در طراحی فعلی تعمیرناپذیر و نادریست است: دو کارمند عمداً هیچ‌گاه دسترسی HR نمی‌گیرند (سرور رد می‌کند)، و اگر فردا تیم HR بزرگ‌تر شد، راه درست ساخت حساب‌های HR بیشتر است – صف بررسی HR ماهیت «صف مشترک با برداشتن پرونده» دارد و از چند حساب HR پشتیبانی کامل می‌کند.

دیاگرام ۱ – جریان فعلی راه‌اندازی سازمان ۳ نفره (۱ مسئول + ۲ HR کارمند)

فاز ۰ – استقرار (خارج از رابط کاربری)

۱ بالا آمدن سرویس → ساخت خودکار حساب «admin» (نقش پشتیبانی، تمام ۹ مجوز) **رمز فقط یک بار در لاگ**

۲ خواندن رمز از لاگ سرویس (docker logs) – اگر از دست برود، راه بازگشت اسکریپت خط فرمان است نه پنل



فاز ۱ – پنل ادمین: ساخت حساب‌های نقش‌دار

۳ ساخت حساب مسئول HR (نقش منابع انسانی) → ۳ مجوز پیش‌فرض خودکار: کاربران، پرسنل، شاخص‌ها

۴ ساخت حساب مدیرعامل – اجباری، چون صندلی مدیرعامل زنجیره خالی‌پذیر نیست؛ سناریوی ۳ نفره شما این نقش را ندارد و ایا چرایی‌اش را نمی‌گویید

۵ فعال‌سازی ماژول‌های سازمانی (نمایش نتیجه به کارکنان، اعتراض و...) – همه ۴ ماژول کارکنان به صورت پیش‌فرض خاموش‌اند



فاز ۲ – ثبت پرسنل و حساب کارمندان (توسط ادمین یا HR)

۶ ثبت دو کارمند + تعیین زنجیره (مسئول مستقیم اختیاری – می‌تواند خود مدیرعامل باشد؛ مدیرعامل اجباری)

۷ ساخت حساب نقش «کارمند» متصل به پرونده پرسنلی → رمز موقت + اجبار تغییر رمز در اولین ورود

۸ ثبت ایمیل/موبایل کاربران ممکن نیست (فقط خود کاربر از صفحه تنظیمات) → اعلان ایمیل/پیامک در ابتدا خاموش است

فاز ۳ – آغاز عملیات (توسط مسئول HR)

۹ ساخت دوره ارزیابی + «ساخت دسته‌ای» پرونده دو کارمند → اعلان درون برنامه‌ای به هر دو

۱۰ زنجیره: مسئول واحد ثبت می‌کند → HR بررسی می‌کند → مدیرعامل نهایی می‌کند → اعلان نتیجه (اگر مازول نمایش نتیجه روشن باشد)

مراحل برچسب‌خورده زرد، نقاط شکست/اصطکاک واقعی این سناریو هستند.

۲/۲ – ماتریس نقش‌ها و دسترسی پیش‌فرض

جدول زیر وضعیت فعلی را دقیق نشان می‌دهد – چه چیزی برای هر نقش خودکار داده می‌شود و چه چیزی باید دستی اعطا شود:

نقش	جایگاه در گردش کار	مجوزهای اداری پیش‌فرض	نکته تخصیص اولیه
پشتیبانی فنی support	هیچ‌جای زنجیره – ۴۰۳ روی همه مسیرهای ارزیابی (عمدی)	تمام ۹ مجوز (فقط حساب bootstrap یا اسکریپت)	از فرم ساخت کاربر قابل انتخاب نیست
منابع انسانی hr	مرحله بررسی بی‌طرف؛ صف مشترک + برداشتن پرونده؛ برای پرونده اعضای واحد HR خودش کنار می‌رود	manage_users، manage_personnel، manage_scoring	خودکار هنگام ساخت/تغییر نقش؛ ولی نه view_diagnostics و manage_integrations
مسئول واحد unit_supervisor	نمره‌دهنده اول (اختیاری – مسیر «مدیر» حذف می‌کند)	هیچ	صندلی زنجیره افراد زیرمجموعه
معاونت deputy	تأیید مرحله‌ای؛ در مسیر «مدیر» نمره‌دهنده اول (اختیاری)	هیچ	صندلی زنجیره
مدیرعامل ceo	تأیید نهایی؛ در زنجیره «مستقیم» نمره‌دهنده اول	هیچ	اجباری – بدون آن هیچ پرسنلی قابل ثبت نیست
کارمند employee	موضوع پرونده؛ دیدن «کارنامه من»، اعتراض، رؤیت، خودارزیابی	هیچ (سرور داده اداری به کارمند را رد می‌کند)	نیازمند پیوند به پرونده پرسنلی؛ در ایمپورت اکسل همزمان ساخته می‌شود

مجوزهای اداری مستقل از نقش‌اند و فقط دارنده manage_capabilities (به‌طور طبیعی: حساب پشتیبانی) می‌تواند آن‌ها را بدهد یا بگیرد. HR پیش‌فرض نمی‌تواند مجوز بدهد – تفکیک وظایف عمدی است.

G1 – بدون حساب «مدیرعامل» کل اوربوردینگ قفل است، و هیچ‌کس نمی‌داند چرا بالا

مدل داده صندلی مدیرعامل را NOT NULL کرده و اعتبارسنجی صندلی‌ها با سلسله‌مراتب نقش انجام می‌شود؛ نقش HR هم عمده‌اً بیرون سلسله‌مراتب زنجیره است و اجازه نشستن در هیچ صندلی ندارد. نتیجه برای سازمان سه‌نفره شما: در فرم ثبت پرسنل، منوی «مدیرعامل» خالی است و فقط پیام «انتخاب کنید» می‌بینید – بدون توضیح اینکه اول باید از تب حساب‌ها یک کاربر مدیرعامل بسازید. کاربر جدید پلتفرم این را حدس نمی‌زند؛ این دقیقاً همان نقطه‌ای است که پیاده‌سازی واقعی چند ساعت گیر می‌کند.

راهکار: (الف) پیام خطای فرم پرسنل وقتی فهرست مدیرعامل خالی است صریح بگوید «ابتدا از تب حساب‌ها کاربری با نقش مدیرعامل بسازید» با لینک مستقیم؛ (ب) برای سازمان‌هایی که واقعاً مدیرعامل ندارند، نقش ترکیبی رسمی تعریف شود: اجازه نشستن حساب HR در صندلی مدیرعامل فقط وقتی زنجیره متعلق به خود اعضای واحد HR نیست و پرونده سپر شود – یا ساده‌تر: یک نقش CEO تشریفاتی که فرد همان سازمان (مثلاً مدیر HR) جدا از حساب HR داشته باشد. حساب‌ها در این سیستم می‌توانند فقط یک نقش داشته باشند، پس راه کم‌دردتر ساخت یک حساب دوم برای همان فرد است.

models/evaluation_access.py:25 · services/workflow.py:689-715 · services/self_evaluation.py:57-66

G2 – ادمین اولیه بیرون از محصول متولد می‌شود و جانشین‌سازی‌اش از پنل ناممکن است بالا

سه لایه مشکل: (۱) رمز bootstrap فقط یک بار در لاگ چاپ می‌شود – گم‌شدنش یعنی بازگشت به خط فرمان و SSH، چیزی که در مدل SaaS سازمان مشتری هیچ دسترسی‌ای به آن ندارد؛ (۲) راهنمای داخل محصول (صفحه مدیریت، بخش تفکیک وظایف) صریحاً می‌گوید «برای تفکیک، یک کاربر با نقش پشتیبانی فنی بسازید» – اما منوی نقش در فرم ساخت و ویرایش کاربر گزینه support ندارد؛ دستورالعملی که داخل خود محصول نوشته شده، داخل همان محصول قابل اجرا نیست؛ (۳) اگر آخرین دارنده manage_capabilities غیرفعال شود، سامانه فقط در ری‌استارت بعدی خودش را بازسازی می‌کند – تا آن لحظه پنل مدیریت کاملاً قفل است و اعلانی هم از این وضعیت به کسی نمی‌رود.

راهکار: گزینه support را به فرم‌های ساخت/ویرایش کاربر اضافه کنید (سرور از قبل پذیرای آن است)؛ و برای ریکاوری، endpoint «رمز ریست ادمین با رمز یک‌بارمصرف نشان‌داده‌شده در لاگ» یا حداقل یک کارت وضعیت در صفحه مدیریت بسازید که «آخرین دارنده مجوز اعطای مجوز» را نمایش دهد و اگر فقط یک نفر است هشدار بدهد.

services/bootstrap_admin.py:100-148 · scripts/create_admin.py · frontend UsersPage.tsx:20 · AdministrationPage.tsx:232-234

G3 – پاک‌سازی تخریبی و بی‌صدا مجوزهای HR هنگام تعریف دوباره نقش متوسط

هر بار که نقش کسی به HR تغییر کند (یا حساب HR جدید ساخته شود)، تابع apply_default_hr_capabilities هر مجوزهای فعلی او را حذف و بعد فقط سه مجوز پیش‌فرض می‌گذارد. سناریوی شکست: ادمین به کارشناس HR مجوز view_audit_log داده؛ ماه بعد نقش او موقتاً به مسئول واحد و دوباره به HR برمی‌گردد → مجوز ممیزی بی‌رسنا می‌پرد و فقط در لاگ ممیزی اگر کسی دنبالش برگردد معلوم می‌شود. مایگريشن معادل هم عمده‌اً IRREVERSIBLE نوشته شده.

راهکار: حذف فقط در «موقعیت تازه» انجام شود؛ وقتی نقش قبلی HR بوده، مجوزهای غیرپیش‌فرض حفظ شوند یا حداقل هشدار صریح «با این تغییر، N مجوز دستی حذف می‌شود» در فرم ویرایش نمایش داده شود.

services/authorization.py:63-71 · api/routers/users.py:217-218, 288-289

G4 – ادمین نمی‌تواند اطلاعات تماس کاربران را ثبت کند؛ اعلان‌های بیرونی بعد از اوربوردینگ خاموش

می‌مانند متوسط

فیلدهای ایمیل و موبایل فقط از صفحه «تنظیمات اعلان‌ها»ی خود کاربر قابل ثبت‌اند؛ نه فرم ساخت کاربر، نه فرم ویرایش، و نه ستون‌های ایمپورت اکسل هیچ‌کدام این دو فیلد را ندارند. پیامد برای سناریوی شما: بعد از راه‌اندازی کامل سازمان، کانال ایمیل و پیامک برای هیچ‌کس فعال نیست تا هر کاربر شخصاً وارد تنظیماتش شود و آدرس بگذارد – و چون پیش‌فرض هر دو کانال هم خاموش است (تصمیم مستند)، عملاً اوربوردینگ «بی‌اعلان بیرونی» تمام می‌شود. خود-پیکربندی برای ۲ نفر شدنی است؛ برای ۲۰۰ نفر هرگز.

راهکار: فیلدهای اختیاری ایمیل/موبایل به فرم ساخت/ویرایش کاربر و دو ستون به ایمپورت اکسل اضافه شود (خودکار تعیین کانال نه – فقط ثبت نشانی؛ انتخاب کانال دست کاربر بماند تا منطق «هیچ‌کس بی‌خبر عضو نمی‌شود» حفظ شود) و در گزارش پایان ایمپورت، آمار «فاقد نشانی تماس» نمایش داده شود.

بدون) schemas/user.py:12-26 · schemas/user.py UserUpdate · services/personnel_import.py:46-81 · api/routers/users.py (فیلد تماس)

G5 – اسکریپت راه‌اندازی سازمان، حساب منابع انسانی و کارمندان را نمی‌سازد

متوسط

مسیر CLI جایگزین (scripts/bootstrap_org.py) از فایل اکسل پرسنلی فقط سه ستون را می‌خواند: مسئول مستقیم، معاونت، مدیرعامل. ستون «منابع انسانی» وجود ندارد و کارمندان هم مقصد این اسکریپت نیستند. یعنی دقیقاً دو نقش سناریوی شما (HR و کارمندان) از این مسیر ساخته نمی‌شوند و دوباره به پنل ادمین برمی‌گردند. ناسازگاری بین دو مسیر راه‌اندازی، منبع گیجی در استقرارهای اولیه است.

راهکار: ستون «مسئول منابع انسانی» به فایل پرسنلی و اسکریپت اضافه شود (اولین نام → ساخت حساب HR با مجوزهای پیش‌فرض)؛ یا بلندمدت، خود این اسکریپت حذف و جایش همان جریان wizard بخش ۲/۴ باید تا فقط یک مسیر راه‌اندازی وجود داشته باشد.

scripts/bootstrap_org.py:53-57

G6 – فرم‌های پنل حساب «پشتیبانی» نمی‌سازند و پرسنل فقط-پشتیبانی فهرست خالی می‌بیند

کم

علاوه بر G2، حساب پشتیبانی که بدون manage_personnel ساخته شود در فرم ساخت کاربر، منوی «پرسنل متناظر» را خالی می‌بیند (پاسخ سرور: صفحه خالی، نه خطا) و بی‌آنکه بفهمد، نمی‌تواند کارمند بسازد. ضمناً کوئری پرسنل این فرم بی‌قید، همیشه ۱۰۰۰ ردیف اول را می‌گیرد – فراتر از آن بی‌صدا بریده می‌شود.

راهکار: پاسخ ۴۰۳/پیام شفاف برای نقش بی‌دسترس، بارگذاری تنبل فهرست پرسنل فقط هنگام بازشدن فرم، و جست‌وجوی سمت سرور برای انتخابگر.

api/routers/personnel.py:237-242 · frontend UsersPage.tsx:50

۲/۴ – فرآیند پیشنهادی: راه‌انداز گام به گام سازمان (Setup Wizard)

به جای اینکه کاربر تازه مجبور باشد بین چهار صفحه پراکنده (حساب‌ها، پرسنل، تنظیمات، مازول‌ها) مسیر را حدس بزند، یک جریان یک‌پارچه «راه‌اندازی سازمان» در پنل ادمین بسازید که فقط تا زمانی نمایش داده شود که سازمان «قابل عملیات» نشده (حداقل یک HR، یک مدیرعامل، یک پرسنل با زنجیره). طراحی پیشنهادی زیر همان قدم‌های اجباری امروز را با پیام‌های درست و ترتیب درست کنار هم می‌آورد:

دیاگرام ۲ – فرآیند راه‌اندازی پیشنهادی (۵ گام، فقط یک مسیر)

گام ۱ – حساب مدیر سامانه (رفع وابستگی به لاگ)

۱ در اولین ورود، سامانه از ادمین bootstrap می‌خواهد رمز خودش را عوض کند (امروز هست) و «حساب جانشین با نقش پشتیبانی فنی» را بسازد (تازه – گزینه support به فرم اضافه شود)

۲ نمایش هشدار دائمی تا وقتی فقط یک دارنده manage_capabilities وجود دارد



گام ۲ – حساب‌های نقش‌دار سازمان

۳ ساخت حساب منابع انسانی (مجوزهای پیش‌فرض خودکار) + ساخت حساب مدیرعامل با توضیح صریح «زنجیره ارزیابی بدون مدیرعامل کار نمی‌کند»

۴ ثبت ایمیل/موبایل هر حساب در همین فرم (اختیاری، با اعتبارسنجی فرمت)



گام ۳ – پرسنل، زنجیره و حساب‌ها (همان ایمپورت اکسل، با فیلدهای تازه)

۵ ایمپورت اکسل با ستون‌های «نام کاربری» و «رمز اولیه» (موجود) + ستون‌های تازه «ایمیل» و «موبایل»

۶ گزارش پایان ایمپورت: آمار حساب‌های ساخته‌شده + فهرست ردیف‌های «بدون نشانی تماس» + رمزهای موقت قابل دانلود CSV (موجود)



گام ۴ – ماژول‌های سازمانی و تنظیم کانال‌ها

۷ فعال‌سازی انتخابی ماژول‌های کارکنان (نمایش نتیجه / اعتراض / رؤیت / خودارزیابی) با توضیح یک‌خطی هرکدام – نه رهاکردن کاربر با ۴ سویچ خاموش

۸ پیکربندی SMTP/پیامک با دکمه «ارسال پیام آزمایشی» (موجود) + کارت وضعیت صف تحویل در همین صفحه (تازه – یافته N1)



گام‌های ۳ و ۵ عمدتاً از قابلیت‌های موجود استفاده می‌کنند؛ تازه‌ها فقط فیلد تماس، گزینه support، هشدار تک‌ادمین و کارت صف تحویل‌اند.

۲/۵ – افق بلندمدت: اگر «پلتفرم چندسازمانی» هدف است

اگر نقشه راه محصول، فروش به چند سازمان روی یک استقرار مشترک است، راهکارهای بالا کافی نیستند و به مدل Tenant نیاز دارید: افزودن organization_id به جدول‌های کاربر، پرسنل، دوره، پرونده، اعلان و تنظیمات؛ فیلتر همه کوئری‌ها با آن (ترجیحاً در لایه session/RLS دیتابیس، نه در هر endpoint)؛ و یک فرآیند ثبت خودخدمتی سازمان: مدیر HR آینده با ایمیل ثبت‌نام می‌کند، حساب owner برایش ساخته می‌شود، و بقیه را با دعوت‌نامه (لینک تعیین رمز یک‌بارمصرف به جای رمز چاپی) اضافه می‌کند. مدل دو لایه نقش/مجوز فعلی این مهاجرت را ساده می‌کند چون تفکیک وظایف از قبل در لایه درست نشسته؛ دشوار کار، پخش‌بودن «تنظیمات سازمانی» بین متغیرهای محیطی، جدول policy و ماژول‌هاست که باید یک‌جا به دامنه سازمان منتقل شوند. تا قبل از آن، هر سازمان = یک استقرار مجزا بماند و در مستندات صریحاً همین گفته شود.

بخش ۳

ماژول دسترسی‌ها و نقش‌ها

معماری دسترسی این پروژه یکی از قوی‌ترین بخش‌هایش است و شایسته است قبل از ایرادها ثبت شود چرا: تفکیک «نقش» (جایگاه در زنجیره ارزیابی) از «مجوز اداری» (Capabilit) از «ماژول» (سوییچ بخش‌ها) سه لایه مستقل ساخته که هر کدام قاعده مشخص دارند. گاردهای خطرناک هم درست نشسته‌اند: کسی نمی‌تواند مجوزی به خودش اضافه کند، آخرین دارنده manage_capabilities نمی‌تواند آن را از خود بگیرد، همه اعطایها لاگ می‌شوند، و «تغییر اجباری رمز» سمت سرور با allowlist قفل شده نه فقط با ریدایرکت فرانت. حذف حساب‌ها به جای DELETE، به غیرفعال‌سازی هدایت می‌شود تا زنجیره هش ممیزی نشکند. این‌ها تصمیم‌های بلوغ‌یافته‌ای هستند. با این حال، شکاف‌های زیر در لایه «قابل استفاده بودن عملی» باقی است:

A1 – حساب قفل‌شده را نمی‌توان از پنل باز کرد و اصلاً معلوم نیست قفل است متوسط

پنج ورود ناموفق = قفل ۱۵ دقیقه‌ای حساب. سرور endpoint بازکردن قفل را دارد (POST /api/users/{id}/unlock) با مجوز manage_users – یعنی HR پیش‌فرض هم دسترسی‌اش را دارد) و برچسب‌های ممیزی «قفل شد/باز شد» در واژگان فرانت هم هست؛ اما هیچ صفحه و دکمه‌ای در کل فرانت این endpoint را صدا نمی‌زند و جدول کاربران هیچ نشانگری از وضعیت قفل ندارد. پیامد: ترکیب «پیام ورود متمایز» (که عمداً «چنین کاربری نیست» از «رمز اشتباه» جدا شده) با قفل خودکار، ابزار مزاحمت همیشگی هم هست؛ حداقل باید مسیر رفعش در دست HR باشد.

راهکار: ستون وضعیت ورود در صفحه حساب‌ها (فعال/قفل تا ...) + دکمه «بازکردن قفل» با تأییدیه + یک اعلان به HR هنگام قفل شدن که مستقیماً به همین دکمه لینک کند (اعلان قفل هست؛ لینکش را به صفحه کاربر ببرید).

(unlock بدون فراخوان) api/routers/users.py:318-350 · services/login_guard.py · frontend UsersPage.tsx

مسیر `/hr/audit-log` گارد مسیری ندارد و به دارنده `view_audit_log` یا `view_diagnostics` پیشنهاد می‌شود؛ اما صفحه از لحظه باز شدن، فهرست واحدهای سازمانی (نیازمند نقش `HR` یا `manage_personnel`) و فهرست کاربران (نیازمند `manage_users`) را می‌گیرد. حساب پشتیبانی با فقط `view_diagnostics` – که دقیقاً همان ترکیب توصیه‌شده «عیب‌یابی بدون دیدن نمره‌ها» است – با دو خطای ۴۰۳ مواجه می‌شود، فیلتر «انجام‌دهنده» خالی می‌ماند و رویدادها بدون قابلیت فیلتر عملاً بی‌فایده‌اند.

راهکار: این دو فهرست را مشروط به داشتن مجوز متناظر بگیرید؛ در نبودشان، فیلتر «انجام‌دهنده» را با جست‌وجوی متنی سمت سرور `endpoint` ممیزی جایگزین کنید یا یک `endpoint` کمکی برای فهرست شناسه/نام کاربری فقط-لاگ بگذارید.

frontend AuditLogPage.tsx:65-66 · api/routers/personnel.py:267-270 · api/routers/users.py:120

این دکمه `POST /api/admin/run-scheduled-jobs` را صدا می‌زند که مجوز `view_diagnostics` می‌خواهد؛ مجوزی که در پیش‌فرض HR نیست. یعنی برای HR استاندارد، دکمه نمایش داده‌شده = خطای تضمینی. اگر هم مدیر سامانه مجوز را بدهد، HR حالا به «سلامت سامانه و صف تحویل» هم دسترسی می‌گیرد – محدوده‌ای بیشتر از آنچه کار می‌کند.

راهکار: یا دکمه فقط به دارنده مجوز نشان شود (چک مجوز در `navItemsFor` هست؛ به دکمه هم بکشید)، یا مجوز مستقل‌تر «اجرا یادآوری‌ها» تعریف شود که منطقش از عیب‌یابی جدا باشد.

frontend DashboardPage.tsx:683-704, 719-725 · api/routers/admin.py:20-47 · services/authorization.py:14-20

مسیرهای `/hr/audit-log` و `/administration` در روتر فرانت گارد نقش/مجاز ندارند (خود صفحه مهربانانه می‌بندد، ولی کارمند کنجکاو با ۴۰۳ بهره‌برداری می‌شود). کارت وضعیت «تفکیک وظایف» و منوی مجوزهای خودی خوب‌اند؛ فقط هماهنگی منو ↔ صفحه در دو مورد بالا جا مانده.

راهکار: گارد کلاینت با `allowedCapabilities` برای دو مسیر یادشده؛ پیام راهنما به‌جای فهرست خالی.

frontend App.tsx:243, 247

ماژول نوتیفیکیشن‌ها

طراحی اعلان‌ها سه‌لایه است: اعلان درون‌برنامه‌ای (همیشه، در همان تراکنش رویداد)، صندوق خروجی (فقط برای انواع «نیازمند اقدام/نتیجه قطعی» با کانال‌های ایمیل و پیامک پیکربندی‌شده)، و جاروی تحویل با `retry` و `backoff` نمایی و تفکیک «شکست گذرا» از «رهاشده» (`abandoned`). تفکیک‌بندی گیرنده‌ها هم دقیق است: صف مشترک HR منهای موضوع پرونده، نمره‌دهنده در برگشت‌ها، خود کارمند در نهایی‌شدن (فقط اگر ماژول نمایش نتیجه روشن باشد)، و اعلان‌های تجمیعی برای خروج پرسنل. مشکل اصلی این‌جا «ساخت» نیست؛ «دیدن» و «پوشش» است:

سه لایه مشکل روی هم: (۱) GET /api/admin/delivery-queue endpoint با مدل داده کامل (وضعیت، تلاش‌ها، خطای آخر، کانال‌های فعال) ساخته شده ولی هیچ صفحه‌ای در کل فرانت از آن استفاده نمی‌کند – جست‌وجوی کل مخزن فرانت برای «diagnostics/تحویل» صفر نتیجه می‌دهد؛ (۲) مجوز دیدنش (view_diagnostics) در پیش‌فرض HR نیست؛ (۳) اعلان رهاشده (abandoned) خودش هیچ اعلانی نمی‌سازد – یعنی آخرین حلقه بازخورد هم بسته نیست. نتیجه خالص: اولین ارسال واقعی سازمان روی SMTP خراب، بی‌صدا و برای همیشه نامرئی می‌ماند تا وقتی کاربر شاکی بشود.

راهکار: صفحه «سلامت اعلان‌ها» (حتی یک کارت ساده در صفحه مدیریت) با شمارش صف + آخرین ۲۰ خطای تحویل + وضعیت کانال‌ها؛ مجوزش view_diagnostics بماند ولی یک نسخه محدود «فقط صف اعلان‌های من ارسال نشده» به HR پیش‌فرض بدهید؛ و بعد از N رهاشدگی پیاپی، یک اعلان درون‌برنامه‌ای به دارنده manage_integrations بفرستید.

api/routers/admin.py:65-111 · services/delivery.py:122-199 · services/schemas/administration.py
(DeliveryQueueSummary)

N2 – نشانی ایمیل/موبایل بدون اعتبارسنجی فرمت ذخیره می‌شود متوسط

اسکیمای تنظیمات اعلان فقط طول را می‌بندد (۳۲۰/۳۲ نویسه) و فرمت را نه؛ فرانت هم فرم را داخل تگ form ندارد پس حتی اعتبارسنجی بومی مرورگر هم اجرا نمی‌شود. کاربر می‌تواند «notify_by_email» را با مقدار abc روشن کند: سامانه تیکی معنادار به او نشان می‌دهد، صف ردیف می‌سازد، کانال شکست می‌خورد، و با N1 نامرئی خطا، هیچ‌کس هرگز نمی‌فهمد. برای پیامک، هزینه واقعی هم دارد.

راهکار: اعتبارسنجی سرور با regex ایمیل و نرمال‌سازی شماره موبایل ایرانی (۰۹... و ارقام فارسی → لاتین، همان سبک نرمال‌سازی اعداد در ایمپورت) + رد روشن‌کردن کانال با نشانی نامعتبر، همان‌جایی که امروز فقط «خالی بودن» را رد می‌کند.

schemas/notification.py:33-41 · api/routers/notifications.py:100-131 · frontend NotificationPreferencesPage.tsx

N3 – کامنت‌های مرحله پرونده هیچ‌کس را مطلع نمی‌کنند متوسط

کامنت اصلی مرحله (که رسماً حامل «دلیل برگشت» و توضیحات رسمی است) هیچ اعلانی نمی‌سازد؛ فقط پاسخ تودرتو به نویسنده کامنت والد اعلان می‌دهد. یعنی اگر مسئول واحد روی پرونده در جریان توضیحی بگذارد، معاونت/HR/مدیرعامل همان پرونده بی‌خبر می‌مانند – و متن اعلان‌های برگشت که می‌گوید «دلیل در کامنت‌های پرونده»، خواننده را به جایی می‌فرستد که خبر جدیدش از راه نرسیده.

راهکار: برای کامنت مرحله‌ای، به «صاحبان دیگر صندلی‌های پرونده + مالک فعلی مرحله» اعلان بدهید با همان قاعده «مگر خودش نویسنده باشد»؛ کانال بیرونی لازم نیست (اطلاع است، نه اقدام).

در برابر: 1936-1887 (پاسخ‌ها اعلان دارند) (notify بدون) 1800-1884 api/routers/evaluations.py

N4 – کارمند هدف «برنامه بهبود» هرگز مطلع نمی‌شود متوسط

ساخت برنامه بهبود فقط به مالک پیگیری اعلان می‌دهد؛ خود کارمند موضوع برنامه – که مسیر «برنامه‌های من» برایش وجود دارد و کسی که برنامه برایش نوشته شده – نه در ساخت، نه در تکمیل و نه در لغو هیچ اعلانی نمی‌گیرد. در نتیجه برنامه‌ای که مشارکت و پیگیری او را فرض می‌کند، در سکوت کامل از سوییچ می‌ماند.

راهکار: سه اعلان به `subject_user_ids`: «برنامه بهبود برای شما ثبت شد»، «برنامه بهبود شما تکمیل/لغو شد»؛ انواعشان را به لیست خروجی هم اضافه کنید (اقدام کارمند را می‌خواهند).

414-403 (مالک جدید)، 449-427 (تکمیل بی‌اعلان)، 474-452 (لغو بی‌اعلان)، (ساخت) 290-301 `api/routers/improvement_plans.py`

N5 – جداول اعلان و تحویل بدون سیاست پاک‌سازی رشد می‌کنند متوسط

تنها حذف اعلان در کل کد، همراه با حذف خود کاربر است؛ جاروی شبانه سه جدول دیگر را پاک می‌کند (تلاش‌های ورود، اقدامات دستیار، نشست‌های مرده) ولی اعلان‌ها و ردیف‌های تحویل را نه. با فن‌اوت‌های چندبرابری (هر رویداد × هر HR)، این دو جدول در بازه چندساله بزرگ‌ترین جدول‌های سیستم می‌شوند و کوئری شمارش «خوانده‌نشده» ی زنگوله – که هر ۵ ثانیه می‌آید – اولین قربانی است.

راهکار: جاروی نگهداری با پیکربندی (مثلاً `notification_retention_days=180`): حذف اعلان‌های خوانده‌شده قدیمی‌تر + ردیف‌های تحویل «sent» قدیمی‌تر؛ «failed/abandoned» تا بررسی باقی بمانند. ایندکس‌ها از قبل درست‌اند.

`services/scheduled.py:555-584` (فهرست جاروها) · `models/notification.py` · `models/notification_delivery.py`

N6 – جاروی «پرونده بی‌صاحب» به HR دستور کاری می‌دهد که رویش ۴۰۳ می‌گیرد متوسط

اعلان لحظه خروج پرسنل، صندلی‌های پرونده‌های سپرده‌شده واحد HR را به معاونت/مدیرعامل همان پرونده می‌فرستد (درست)؛ اما جاروی شبانه‌ی پرونده‌های گیرکرده همه گیرکرده‌ها را یک‌جا به همه HRها می‌فرستد – از جمله پرونده‌های سپرده‌ای که HR نه می‌بیند، نه می‌تواند مسئولش را عوض کند و نه می‌تواند لغو کند. نتیجه: یادآوری تکرارشونده کاری ناممکن؛ همان الگویی که تیم پروژه در جای دیگر برای حل ساخته ولی این جارو جا مانده.

راهکار: همان تفکیک `hr_panel_is_shielded` در جارو: غیرسپرده → HR؛ سپرده → معاونت و مدیرعامل همان پرونده.

(الگوی درست) 268-386 `services/notifications.py` در برابر 331-395 `services/scheduled.py`

N7 – اطلاع‌رسانی‌های ناقص کوچک‌تر کم

چهار مورد که هرکدام یک خط اصلاح‌اند ولی تجربه روزمره را می‌سازند: (۱) تغییر مسئول مرحله فقط به مسئول «جدید» اعلان می‌دهد؛ مسئول قبلی که پرونده از دستش درآمد بی‌خبر است؛ (۲) اعلان قفل‌شدن حساب، هر بار با کلید تکرار تازه می‌آید – مهاجم مصمم می‌تواند زنگوله HR را با اسپم پر کند؛ کلید تکرار را به «کاربر قفل‌شده» گره بزنید نه به زمان قفل؛ (۳) ساخت تکی پرونده به هیچ‌کس اعلان نمی‌دهد (ساخت دسته‌ای می‌دهد) – برای مسیر «مستقیم مدیرعامل» که خودش باز می‌کند، بی‌ضرر است؛ برای بقیه شکل‌های آینده یک اعلان «پرونده روی میز شماس» منسجم‌تر است؛ (۴) اعتراض ثبت‌شده SLA پیگیری ندارد – در جاروها یادآور «اعتراض پاسخ‌نداده N روزه» به همان سطح پاسخ‌دهنده اضافه شود.

`api/routers/evaluations.py:1618-1706`, 1427-1492 · `services/login_guard.py:137-160` · `api/routers/evaluations.py:365-506` · `services/scheduled.py`

آنچه درست است و دست نخورد: صف مشترک HR با برداشتن پرونده (claim) و قفل ردیفی در برابر رقابت، اعلان‌های تجمیعی با هشت مجموعه پرونده‌ها، حذف اعلان «به خود اقدام‌کننده» در مسیرهای یک‌نفره، و وابستگی اعلان نتیجه به مازول نمایش نتیجه (که کارمند را به دربی بسته نبرد). این‌ها را به‌عنوان الگو حفظ کنید.

بخش ۵

ماژول مسیر پرونده (زنجیره ارزیابی)

قلب محصول، زنجیره تأیید چهارمرحله‌ای است و پایدارترین کد مخزن همین‌جاست: ماشین حالت اعلانی با ۱۹ گذار، هر گذار با نقش مجاز، صندلی مشخص، شرط شکل زنجیره و پیام خطای فارسی دقیق؛ پنج شکل زنجیره (کامل، بی‌معاونت، مسیر «مدیر»، مستقیم مدیرعامل، و پرونده اعضای واحد HR بدون مرحله HR) همه از یک جدول واحد می‌گذرند؛ صف HR با برداشتن پرونده و قفل ردیفی در برابر رقابت کار می‌کند؛ «سپر واحد منابع انسانی» پرونده هم‌تیمی‌ها را از پنل HR بیرون نگه می‌دارد؛ و مسیر خروج پرسنل (لغو خودکار + باطل‌سازی نشست‌ها + اعلان صندلی‌های خالی) از بن‌بست‌های رایج عبور کرده. دیاگرام زیر پنج شکل زنجیره را یک‌جا نشان می‌دهد:

دیاگرام ۳ – پنج شکل زنجیره ارزیابی و جایگاه مرحله‌ها

شکل زنجیره	ترتیب کار	قاعده کلیدی
کامل	مسئول واحد ← HR ← معاونت ← مدیرعامل	شکل استاندارد؛ HR داور بی‌طرف وسط
بی‌معاونت	مسئول واحد ← HR ← مدیرعامل	مدیرعامل از hr_approved نهایی می‌کند؛ برگشتش به صف HR برمی‌گردد
مسیر «مدیر»	معاونت (نمره) ← HR ← مدیرعامل	صندلی مسئول واحد ندارد؛ مرحله HR حذف نمی‌شود
مستقیم مدیرعامل	مدیرعامل (نمره) ← HR (نهایی)	امضای نهایی با HR است تا کسی کار خودش را امضا نکند
عضو واحد HR	مسئول واحد/معاونت ← مدیرعامل	مرحله HR عمداً ندارد؛ سپر تا پایان باز بودن؛ اعتراض یک پله بالاتر می‌رود

برگشت پرونده از هر مرحله با ذکر دلیل (کامنت خودکار) یک تا سه پله عقب است و امتیازها حفظ می‌شوند.

W1 – مدیرعامل نشسته در صندلی معاونت می‌تواند تأیید و برگشت بزند، ولی کامنت مرحله‌اش ۴۰۳

می‌دهد متوسط

باگ شناخته‌شده «برگشت بر اساس نقش، تأیید بر اساس صندلی» در کد فعلی واقعاً برطرف شده و انتخاب گزار برگشت حالا صندلی‌محور است – مستند open-findings.md در این مورد عقب است. اما در همان پرسونا (مدیرعاملی که برای چند نفر خودش مسئول مستقیم است و در صندلی معاونت نشسته)، جدول کامنت مرحله هنوز نقش‌محور است؛ او در وضعیت hr_approved به‌جای کامنت صندلی معاونت، کامنت مدیرعامل را می‌گیرد که در آن وضعیت مجاز نیست → ۴۰۳ «در این مرحله امکان ثبت کامنت برای شما وجود ندارد». یعنی همان آدمی که می‌تواند پرونده را برگرداند، نمی‌تواند بنویسد چرا.

راهکار: نگاشت کامنت هم صندلی‌محور شود: اگر شناسه کاربر در صندلی معاونت پرونده است و وضعیت با آن مرحله سازگار است، کامنت همان مرحله را بپذیر – صرف‌نظر از نقش حساب.

در برابر اصلاح: 1110-1131 (برگشت صندلی‌محور) api/routers/evaluations.py:1825-1838

W2 – کارمند از لغو پرونده خودش اعلان نمی‌گیرد متوسط

در هر سه گزار لغو (دستی HR، لغو مسیر واحد HR، لغو خودکار هنگام خروج) گیرندگان فقط صندلی‌های زنجیره‌اند: مسئول واحد، معاونت، مدیرعامل. موضوع پرونده – کسی که منتظر نتیجه ارزیابی خودش است – هیچ‌گاه در فهرست نیست. کارمندی که پرونده باز داشته و پرونده‌اش به‌خاطر «خروج تأییدکننده» یا «تخصیص اشتباه» لغو شده، از «کارنامه من» منتظر نتیجه می‌ماند و هیچ‌کس موظف به خبردادن نیست.

راهکار: در گزارهای لغو، به subject_user_ids هم اعلان «پرونده ارزیابی شما لغو شد؛ برای پیگیری با منابع انسانی در تماس باشید» بدهید (به‌جز لغو خودکار خروج خود فرد که گیرنده‌اش دیگر عضو نیست). متن اعلان فعلی هم این پیام را از صندلی‌ها پنهان نمی‌کند، پس افزودن موضوع پرونده فقط یک ردیف گیرنده اضافه می‌کند.

services/workflow.py:469-475 (cancel فهرست گیرندگان) · services/notifications.py:463-475

W3 – دو مورد مستندسازی/داده‌ای کوچک کم

(۱) مستند open-findings.md دو مورد از یافته‌هایش را هنوز «باز» نشان می‌دهد که در کد فعلی بسته‌اند (برگشت صندلی‌محور، و رفتار تازه‌سازی مجوزهای فرانت) – مستندی که با کد نمی‌خواند، اعتماد به کل مستندات را می‌سوزاند؛ بهتر است بالای فایل تاریخ «آخرین هم‌راستاسازی با کد» بیاید. (۲) «کد پرسنلی» تکراری هنگام ثبت همزمان، از مسیر چک-و-بنویس رد می‌شود و خطای یکتایی دیتابیس کنترل‌نشده → ۵۰۰؛ همان الگوی «نام کاربری تکراری» که در کاربران با پیام فارسی هندل شده، این‌جا هم اعمال شود. (۳) اختلاف گردکردن پیش‌نمایش/سند از یافته‌های باز خود پروژه است و همچنان پابرجاست – جایی که پیش‌نمایش ۳۱/۳ و سند چاپی ۳۱/۲ می‌گوید، مشتری دعوا می‌کند.

services/evaluation.py در برابر frontend utils/rounding.ts · api/routers/personnel.py:654-661 · docs/open-findings.md:58-63

بخش ۶

پایداری، عملیات و تجربه کاربری

زیرساخت زمان‌بندی (قفل مشاوره‌ای Postgres با اتصال اختصاصی و رهایش تضمینی، ثبت هر اجرا در جدول scheduler_runs، و جاروهای SLA/انقضای قرارداد/پرونده بی‌صاحب با dedup و منطقه زمانی تهران) سالم و اندازه‌گیری شده است. یافته‌های این بخش از جنس «پیکرپندی استقرار» و «جزئیات تجربه» هستند:

محدودیت «۱۰ ورود در دقیقه» در حافظه هر ورکر نگه داشته می‌شود؛ پیکربندی Redis برایش وجود دارد ولی تنها با یک توضیح در کامنت – برخلاف نگهبان‌های سخت‌گیرانه همسایه‌اش (رمز JWT، دمو‌ی seed، پروکسی و...) که در پروداکشن اجرا را می‌شکنند، این یکی نمی‌شکند. نتیجه: با ۴ ورکر، عملاً ۴۰ ورود در دقیقه و بازنشستگی با هر ری‌استارت.

راهکار: در حالت production، خالی‌بودن rate_limit_storage_uri وقتی بیش از یک ورکر پیکربندی شده، به‌عنوان خطای بالا آمدن یا هشدار پررنگ لاگ شود – هم‌راستا با سخت‌گیری بقیه نگهبان‌ها.

(و مقایسه با نگهبان‌های 204-292) core/config.py:96-100

02 – تجربه نشست منقضی و جزئیات ورود کم

انقضای توکن با یک رفرش single-flight بی‌صدا ترمیم می‌شود و در شکستش، کاربر با hard-redirect به صفحه ورود می‌رود – بدون هیچ پیامی مثل «نشست شما منقضی شد؛ دوباره وارد شوید»، و فرم بدون خطا شبیه «چیزی شکست» به نظر می‌رسد. سه مورد ریز دیگر: (۱) تمایز عمدی «چنین کاربری نیست / رمز اشتباه» که شمارش حساب‌های معتبر را ممکن می‌کند – تصمیم مستند تیم است و فقط یادآوری می‌شود که با قفل ۱۵ دقیقه‌ای ترکیبش ابزار مزاحمت است (راهکارش در A1 پوشش داده شد)؛ (۲) نگهداری توکن دسترسی فقط در حافظه + کوکی HttpOnly رفرش، انتخاب درستی است و حفظش شود؛ (۳) پاک‌سازی کامل کش کوئری‌ها در خروج، ریسک باقی‌ماندن داده روی رایانه مشترک را بسته – خوب است.

frontend api/client.ts:24-45, 75-85 · api/routers/auth.py:152-167

03 – بهبودهای ریز رابط که در بازبینی دیده شد کم

(۱) صفحه تنظیمات اعلان‌ها فرم واقعی (form) نیست؛ با اعتبارسنجی سرور N2، دو کیلوبایت هم اصلاح فرانت می‌ارزد که فرمت پیش از ارسال چک شود. (۲) در صفحه پرسنل، وقتی هیچ کاربر مدیرعاملی نیست، منوی «مدیرعامل» فقط پیام «انتخاب کنید» دارد – پیام راهنمای اتصال به تب حساب‌ها (پیوند G1). (۳) دو سویچ ماژول/سیاست که قبلاً جهتشان برعکس بود، در کد فعلی هم‌جهت شده‌اند؛ مستند باز findings عقب است. (۴) چهار ماژول مسیر کارکنان به‌صورت پیش‌فرض خاموش‌اند و هیچ نقطه‌ای در UI به ادمین نمی‌گوید «برای دیدن نتیجه توسط کارمندان، این را روشن کن» – در wizard پیشنهادی بخش ۲/۴ پوشش داده شد.

frontend NotificationPreferencesPage.tsx · PersonnelPage.tsx (منوی مدیرعامل) · core/modules.py:31-92

جدول خلاصه یافته‌ها و اولویت‌بندی

تمام یافته‌ها در یک نگاه؛ شناسه‌ها همان‌هایی هستند که در متن با راهکار آمده‌اند. «اثر» کوتاه‌شده پیامد عملیاتی است:

شناسه	عنوان	ماژول	شدت	اثر در یک خط
N1	نامرئی‌بودن شکست اعلان بیرونی (نبود UI صف تحویل)	نوتیفیکیشن	بالا	خرابی کانال برای همیشه بی‌صدا

شناسه	عنوان	ماژول	شدت	اثر در یک خط
G2	ادمین bootstrap بیرون از پنل + رمز در لاگ + نبود نقش support در UI	دسترسی‌ها	بالا	ریسک قفل کامل مدیریت
G1	زنجیره بدون مدیرعامل قفل است؛ UI نمی‌گوید	مسیر پرونده	بالا	اوربوردینگ اولین سازمان گیر می‌کند
G3	پاک‌سازی بی‌صدا مجوزها هنگام تعریف دوباره HR	دسترسی‌ها	متوسط	مجوز دستی ناپدید می‌شود
G4	ادمین نمی‌تواند ایمیل/موبایل کاربران را ثبت کند	دسترسی‌ها	متوسط	اعلان بیرونی پس از اوربوردینگ خاموش
G5	bootstrap_org.py ستون HR ندارد	اوربوردینگ	متوسط	دو مسیر ناسازگار راه‌اندازی
A1	نبود UI بازکردن قفل حساب	دسترسی‌ها	متوسط	تعطیلی ۱۵ دقیقه‌ای بی‌راه‌حل
A2	۴۰۳ تضمینی در صفحه رویدادها برای عیب‌یاب	رابط کاربری	متوسط	عیب‌یابی بدون فیلتر کارساز
A3	دکمه یادآوری‌های HR همیشه ۴۰۳	رابط کاربری	متوسط	دکمه شکست تضمینی
N2	نبود اعتبارسنجی فرمت ایمیل/موبایل	نوتیفیکیشن	متوسط	شکست تحویل و هزینه SMS
N3	کامنت مرحله اطلاع‌رسانی ندارد	نوتیفیکیشن	متوسط	دلیل برگشت‌ها بی‌خبر می‌ماند
N4	کارمند برنامه بهبود بی‌اعلان	نوتیفیکیشن	متوسط	برنامه در سکوت از سوی فرد
N5	بدون retention برای اعلان/تحویل	پایداری	متوسط	رشد بی‌سقف جداول
N6	جاروی بی‌صاحب‌ها به HR کار سپرده می‌دهد	نوتیفیکیشن	متوسط	یادآوری کار ناممکن
W1	کامنت صندلی معاونت برای CEO نشسته ۴۰۳	مسیر پرونده	متوسط	برگشت‌دهنده نمی‌تواند بنویسد چرا
W2	کارمند از لغو پرونده خودش بی‌خبر	مسیر پرونده	متوسط	انتظار بی‌پایان برای نتیجه
O1	rate-limit چندورکری بی‌نگهبان	پایداری	متوسط	سقف ورود واقعاً N برابر
G6	پشتیبانی بی‌مجوز: فهرست خالی بی‌توضیح + برش ۱۰۰۰	اوربوردینگ	کم	گیجی ادمین محدودشده
A4	مسیرهای بدون گارد کلاینت	رابط کاربری	کم	۴۰۳ به صورت بی‌هدف
N7	بسته چهار اعلان ناقص ریز (reassign، اسپم قفل، ساخت تکی، SLA اعتراض)	نوتیفیکیشن	کم	پوشش اطلاع‌رسانی ناقص
W3	مستند عقب از کد؛ ۵۰۰ برای کد پرسنلی تکراری؛ گردکردن پیش‌نمایش/سند	مسیر پرونده	کم	اعتماد مستندات؛ دعوای عددی
O2	نشست منقضی بی‌پیام؛ enumeration عمدی	پایداری	کم	گیجی کاربر؛ مزاحمت قابل مهار
O3	بهبودهای ریز رابط (فرم اعلان، منوی مدیرعامل، ماژول‌های خاموش)	رابط کاربری	کم	اصطکاک روزمره

نقشه راه پیشنهادی سه‌فازی

فاز	تلاش تقریبی	اقدام‌ها (به ترتیب اجرا)
فاز ۱ – هفته جاری رفع ریسک استقرار و نامرئی بودن	۲ تا ۳ روز	(۱) صفحه/کارت «سلامت اعلان‌ها» روی endpoint موجود صف تحویل (N1)؛ (۲) گزینه support در فرم‌های کاربر + هشدار «تک‌ادمین» (G2)؛ (۳) پیام راهنمای «مدیرعامل ندارید → ابتدا حساب بسازید» در فرم پرسنل (G1)؛ (۴) اعلان لغو به موضوع پرونده (W2)؛ (۵) اعلان‌های برنامه بهبود به فرد موضوع (N4)
فاز ۲ – ماه جاری بستن حلقه‌های اطلاع‌رسانی و عملیات	۴ تا ۶ روز	(۱) اعتبارسنجی فرمت نشانی تماس + فرم اعلان‌ها (N2، O3)؛ (۲) اعلان کامنت مرحله‌ای (N3)؛ (۳) UI بازکردن قفل + نشانگر وضعیت (A1)؛ (۴) اصلاح جاروی بی‌صاحب‌ها برای پرونده‌های سپرده (N6)؛ (۵) نگهداری جداول اعلان با پیکربندی (N5) retention؛ (۶) فیلدهای ایمیل/موبایل در فرم کاربر و ایمپورت اکسل (G4)؛ (۷) صندلی‌محور کردن کامنت مرحله (W1)؛ (۸) نگهدارنده پیکربندی rate-limit چندورکری (O1)
فاز ۳ – یک فصل تجربه راه‌اندازی و مقیاس	۲ تا ۳ هفته	(۱) Setup Wizard پنج‌گامی (دیاگرام ۲) با مفهوم «سازمان آماده»؛ (۲) دعوت‌نامه تعیین رمز به جای رمز چاپی/پیامی؛ (۳) هم‌راستاسازی و سپس جمع اسکریپت bootstrap_org؛ (۴) تصمیم‌نامه معماری چندسازمانی (بخش ۲/۵) – اگر هدف SaaS است، مدل Tenant از همین جا طراحی شود؛ (۵) بازگشت‌پذیرکردن مایگريشن‌های تخریبی یا حداقل چک‌لیست بکاپ پیش از ارتقا

معیار پذیرش پیشنهادی برای فاز ۱: یک نصب تازه در محیط تمیز، فقط با خواندن پیام‌های داخل محصول و بدون مراجعه به مستندات، تا «ساخت دسته‌ای اولین دوره ارزیابی» برود – اگر شد، سناریوی «۱ + HR کارمند» شما حل شده است.

پیوست فنی: مراجع خط‌به‌خط

برای هر یافته، نقطه دقیق در کد (نسخه کامیت 27c83e5) برای شروع مستقیم اصلاح. مسیرها نسبت به ریشه مخزن:

شناسه	فایل‌ها و توضیح محل
G1	· (ceo NOT NULL) backend/app/models/evaluation_access.py:25 · (may_act_at و HR بدون CHAIN_RANK_) backend/app/services/workflow.py:689-715 · (REDUNDANT_PAIRS_) backend/app/services/self_evaluation.py:57-66 (AccessFields؛ منوی مدیرعامل بدون پیام راهنما) frontend/src/pages/hr/PersonnelPage.tsx

شناسه	فایل‌ها و توضیح محل
G2	· backend/app/services/bootstrap_admin.py:100-148 (ensure_bootstrap_admin؛ رمز یک‌بار در لاگ) · frontend/src/pages/hr/UsersPage.tsx:20 (CLi ریکویری) backend/scripts/create_admin.py · frontend/src/pages/hr/AdministrationPage.tsx:232-234 (support (راهنمای تفکیک)
G3	· backend/app/services/authorization.py:14-20, 63-71 (DEFAULT_HR_CAPABILITIES و apply_default_hr_capabilities) · backend/app/api/routers/users.py:217-218, 288-289 (فراخوانی‌ها) · backend/alembic/versions/f2a7d3c9e861_set_hr_default_capabilities.py (تخریبی و IRREVERSIBLE)
G4	· backend/app/api/routers/users.py (UserCreate بدون فیلد تماس) · backend/app/schemas/user.py:12-26 (UserUpdate بدون فیلد تماس) · backend/app/services/personnel_import.py:46-81 (COLUMNS بدون ایمیل/موبایل) · backend/app/api/routers/notifications.py:100-131 (تنها نقطه ثبت تماس – خود کاربر)
G5	· backend/scripts/bootstrap_org.py:53-57 (COLUMN_ROLES_: فقط مسئول/معاونت/مدیرعامل)
G6	· backend/app/api/routers/personnel.py:237-242 (خالی برای نقش بی‌ستون) · frontend/src/pages/hr/UsersPage.tsx:50 (usePersonnelList بی‌قید limit=1000)
A1	· backend/app/api/routers/users.py:318-350 (unlock – بدون مصرف‌کننده فرانت) · backend/app/services/login_guard.py (قفل ۵ تا ۱۵ دقیقه) · frontend/src/types.ts:577-578 (برچسب‌های ممیزی موجود)
A2	· frontend/src/pages/hr/AuditLogPage.tsx:65-66 (دو کوئری بی‌مجون) · backend/app/api/routers/personnel.py:267-270 و users.py:120 (گازدها)
A3	· frontend/src/pages/hr/DashboardPage.tsx:683-704, 719-725 · backend/app/api/routers/admin.py:20-47 (view_diagnostics نیازمند run-scheduled-jobs)
N1	· backend/app/api/routers/admin.py:65-111 (delivery-queue – بدون مصرف‌کننده فرانت) · backend/app/services/delivery.py:35-55, 122-199 (OUTBOUND_TYPES و جارو) · backend/app/core/config.py:195-198 (تنظیمات تحویل)
N2	· backend/app/schemas/notification.py:33-41 (فقط max_length) · backend/app/api/routers/notifications.py:100-131 · frontend/src/pages/NotificationPreferencesPage.tsx:49-66 (فرم بدون form)
N3	· backend/app/api/routers/evaluations.py:1800-1884 (add_comment بدون notify) در برابر 1887-1936: · add_reply (اعلان دارد)
N4	· backend/app/api/routers/improvement_plans.py:290-301, 403-414, 427-449, 452-474
N5	· backend/app/services/scheduled.py:555-584 (purge بدون اعلان) · backend/app/api/routers/users.py:399 (تنها حذف اعلان)
N6	· backend/app/services/scheduled.py:331-395 (جاروی بی‌صاحب) در برابر services/notifications.py:268-386 (الگوی درست خروج پرسنل)
N7	· login_guard.py:137-160 (کلید dedup قفل) · evaluations.py:1618-1706, 1427-1492 (reassign/handover) · evaluations.py:365-506 (ساخت تکی)

شناسه	فایل‌ها و توضیح محل
W1	backend/app/api/routers/evaluations.py:1825-1838 (برگشت صندلی‌محور – الگو) stage_by_role نقش‌محور) در برابر 1131-1087:
W2	services/notifications.py:463-475 · backend/app/services/workflow.py:469-475 (گیرندگان cancel)
W3	docs/open-findings.md:58-63, 88-91 (موارد بسته‌شده در کد) · backend/app/api/routers/personnel.py:654-661 (چک-و-بنویس کد پرسنلی) · services/evaluation.py در برابر frontend/src/utls/rounding.ts
O1	backend/app/core/config.py:96-100 (rate_limit_storage_uri) · مقایسه با نگهبان‌های پروداکشن 292-204:
O2	backend/app/api/routers/auth.py:152-167 · frontend/src/api/client.ts:24-45, 75-85

روش بازبینی: کل بک‌اند FastAPI (مدل‌ها، سرویس‌ها، روترها، مایگريشن‌ها و تست‌ها) و کل فرانت‌اند React/TypeScript مرور شد؛ چهار محور درخواستی به صورت خطبه‌خط دنبال شد؛ سناریوی راه‌اندازی، از نصب تازه تا «ساخت دسته‌ای ارزیابی»، روی کد شبیه‌سازی و همه گاردها دنبال شد. هر یافته قبل از گزارش، در کد فعلی راستی‌آزمایی شده و دو مورد از یافته‌های مستند داخلی پروژه که در نسخه فعلی برطرف‌اند، به عنوان «بسته‌شده» ثبت شده‌اند. محدودیت: اجرای پویا (حمله واقعی یا لود تست) در اسکوپ نبود؛ ارقام کارایی گزارش نشده چون تیم پروژه از قبل مبنای اندازه‌گیری دارد (docs/perf-3b.md).

پایان گزارش

از یک ماشین حالت سالم، یک راه‌اندازی سالم بسازید.

زیرساخت هست؛ تسلسل استقرار باقی مانده: حساب‌های اولیه، اعلان‌های قابل‌اعتماد، و مسیری که کاربر تازه بدون حدس بپیماید. فاز ۱ همین هفته می‌بندد.